

Firewalls and IDS

Cybersecurity

25 Feb. 2026

What is a Firewall?

- a **choke point** of control and monitoring
- interconnects networks with differing trust
- imposes restrictions on network services
 - only authorized traffic is allowed
- auditing and controlling access
 - can implement alarms for abnormal behavior
- provide NAT & usage monitoring
- implement VPNs using IPSec
- must be immune to penetration

What is a Firewall?

Firewall

Firewall is a single point of defense between two networks.

Firewall is hardware / software

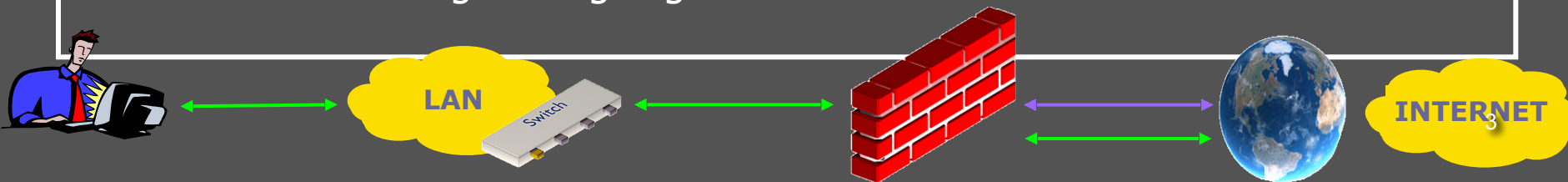
- firewalls protect the resources of a private network from users from other networks.
- The firewall enforces access control between two networks.
- The firewall allows or denies the traffic to/from the network.
- firewalls are essential for the integrity and confidentiality of the information present in the internal network.

Organization , universities , companies use firewall systems

Firewall can act as gateway

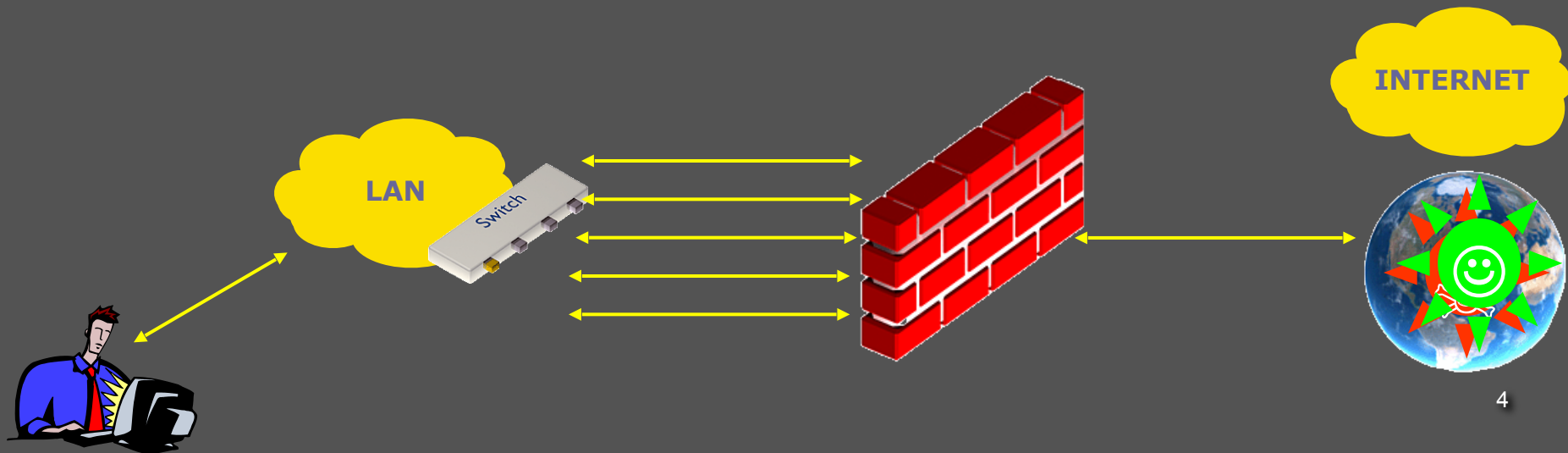
Firewall can act as proxy

Firewall filter Incoming & Outgoing information

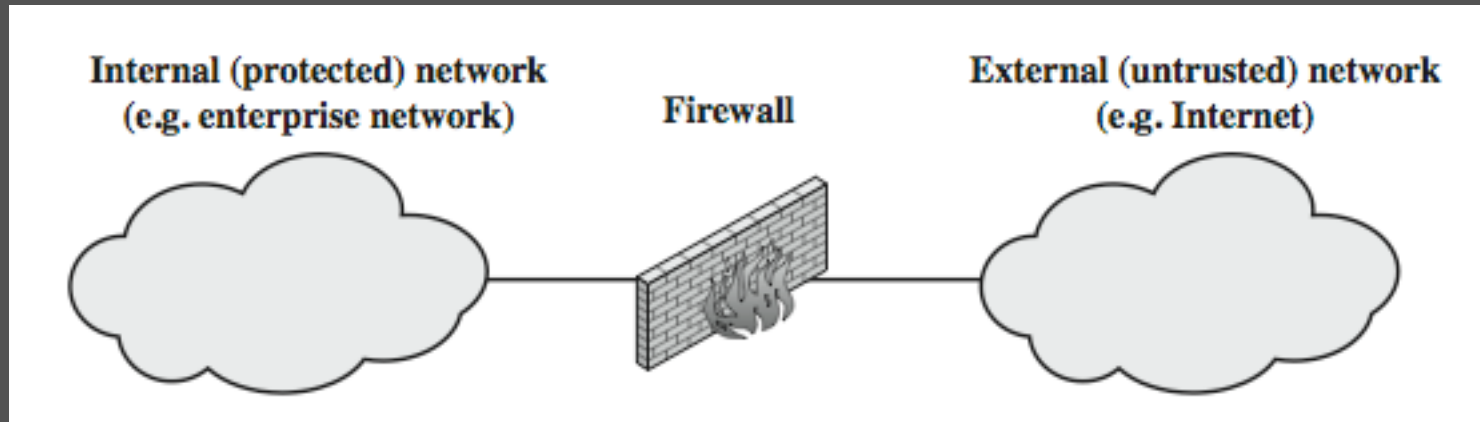


Main purpose of using firewalls

- Packet filtering
 - Analyzing packets
- Proxy service
 - Provide access to other networks e.g INTERNET



What is a Firewall?



Firewall Limitations

- cannot protect from attacks bypassing it
 - eg sneaker net, utility modems, trusted organisations, trusted services (eg SSL/SSH)
- cannot protect against internal threats
 - eg disgruntled or colluding employees
- cannot protect against access via WLAN
 - if improperly secured against external use
- cannot protect against malware imported via laptop, PDA, storage infected outside

Types of Firewalls

- Firewalls can be categorized based on the OSI model level at which they operate, there are 3 basic types of firewalls:
 - Network level (Packet filters)
 - Application level (Proxy server)
 - Circuit level (Proxy server)

Firewalls – Packet Filters

- simplest, fastest firewall component
- foundation of any firewall system
- examine each IP packet (no context) and permit or deny according to rules
- hence restrict access to services (ports)
- possible default policies
 - that not expressly permitted is prohibited
 - that not expressly prohibited is permitted

Firewalls – Packet Filters

- Network level firewalls operate on the network level of the OSI model.
- It filters each incoming packet to determine whether to pass it through the network.
- Network level firewalls employ one of two different filtering approaches:
 - Static packet filtering.
 - Dynamic packet filtering/Stateful inspection.

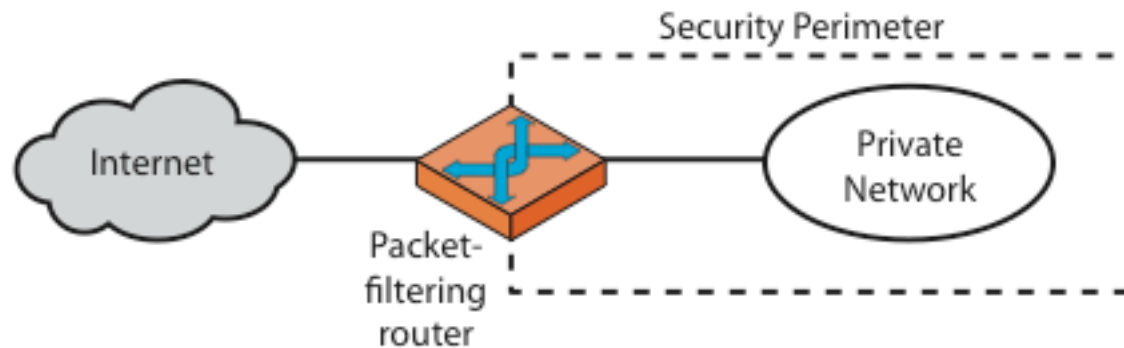
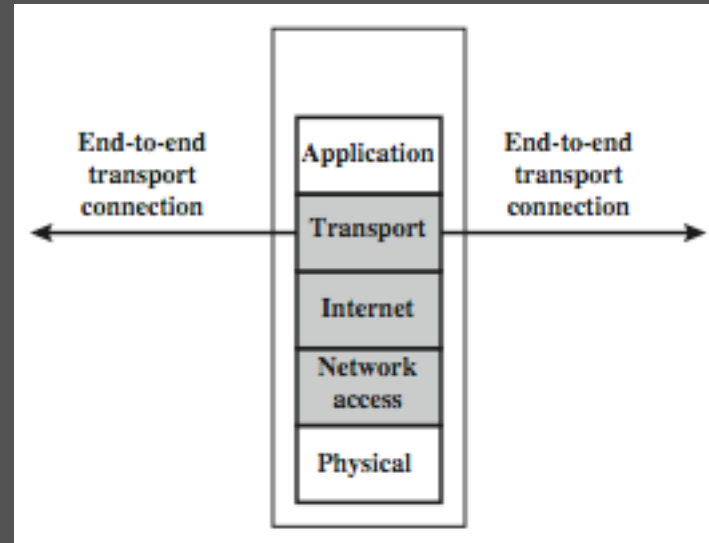
Static Packet Filtering

- A static packet filter is one of the foremost firewall technologies (first generation) that analyze network traffic.
- A static packet filtering firewall filters incoming and outgoing packets to deny or authorize access based on some rules defined by the administrator.
- The filtering rules are non-dynamic (they do not change/static).
- Static packet filters do not understand the application layer protocols used in the communication packets.

Static Packet Filtering

- The following factors allow or deny the data flow through the packet filters:
 1. The physical network interface that the packet arrives on.
 2. the address the data is coming from.
 3. The address the data is going to.
 4. The type of transport layer protocol, TCP or UDP.
 5. The transport layer source port.
 6. The transport layer destination port.

Firewalls – Packet Filters



(a) Packet-filtering router

Filtering Rules - Examples

<u>Policy</u>	<u>Firewall Setting</u>
No outside Web access.	Drop all outgoing packets to any IP address, port 80
External connections to public Web server only.	Drop all incoming TCP SYN packets to any IP except 222.22.44.203, port 80
Prevent IPTV from eating up the available bandwidth.	Drop all incoming UDP packets - except DNS and router broadcasts.
Prevent your network from being used for a Smurf DoS attack.	Drop all ICMP packets going to a "broadcast" address (eg 222.22.255.255).
Prevent your network from being tracerouted	Drop all outgoing ICMP

Access control lists

Apply rules from top to bottom:

action	source address	dest address	protocol	source port	dest port
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023
deny	all	all	all	all	all

Firewalls – Packet Filters

Table 20.1 Packet-Filtering Examples

A	action	ourhost	port	theirhost	port	comment
	block	*	*	SPIGOT	*	we don't trust these people
	allow	OUR-GW	25	*	*	connection to our SMTP port

B	action	ourhost	port	theirhost	port	comment
	block	*	*	*	*	default

C	action	ourhost	port	theirhost	port	comment
	allow	*	*	*	25	connection to their SMTP port

D	action	src	port	dest	port	flags	comment
	allow	{our hosts}	*	*	25		our packets to their SMTP port
	allow	*	25	*	*	ACK	their replies

E	action	src	port	dest	port	flags	comment
	allow	{our hosts}	*	*	*		our outgoing calls
	allow	*	*	*	*	ACK	replies to our calls
	allow	*	*	*	>1024		traffic to nonservers

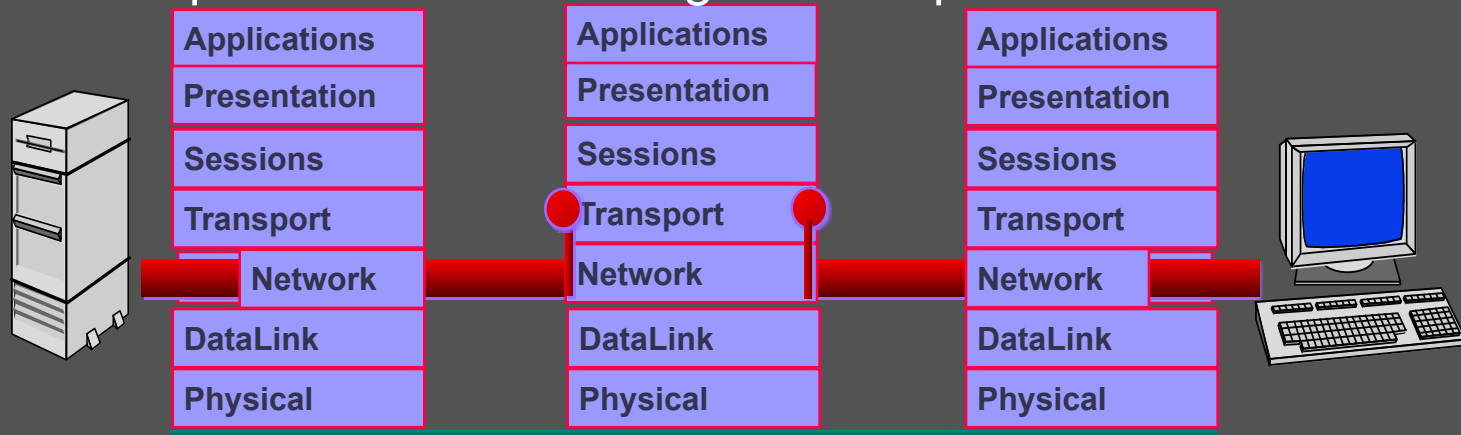
Static Packet Filtering

- **Advantages**

- Generally faster than other firewalls because they perform fewer evaluations.
- Less complicated, in the sense that a single rule controls deny or allow of packets.
- Can provide NAT -- Network Address Translation
- Least Expensive.
- They do not require client computers to be configured specially.

- **Disadvantages**

- Limited capabilities -- typically only Source & Destination
- Cannot address protocol subsets other than IP -- most TCP
- Cannot perform checks on higher-level protocols.



Attacks on Packet Filters

- IP address spoofing
 - fake source address to be trusted
 - add filters on router to block
- source routing attacks
 - attacker sets a route other than default
 - block source routed packets
- tiny fragment attacks
 - split header info over several tiny packets
 - either discard or reassemble before check

Firewalls – Stateful Packet

- traditional packet filters do not examine higher layer context
 - i.e., matching return packets with outgoing flow
- stateful packet filters address this need
- they examine each IP packet in context
 - keep track of client-server sessions
 - check each packet validly belongs to one
- hence are better able to detect bogus packets out of context
- may even inspect limited application data

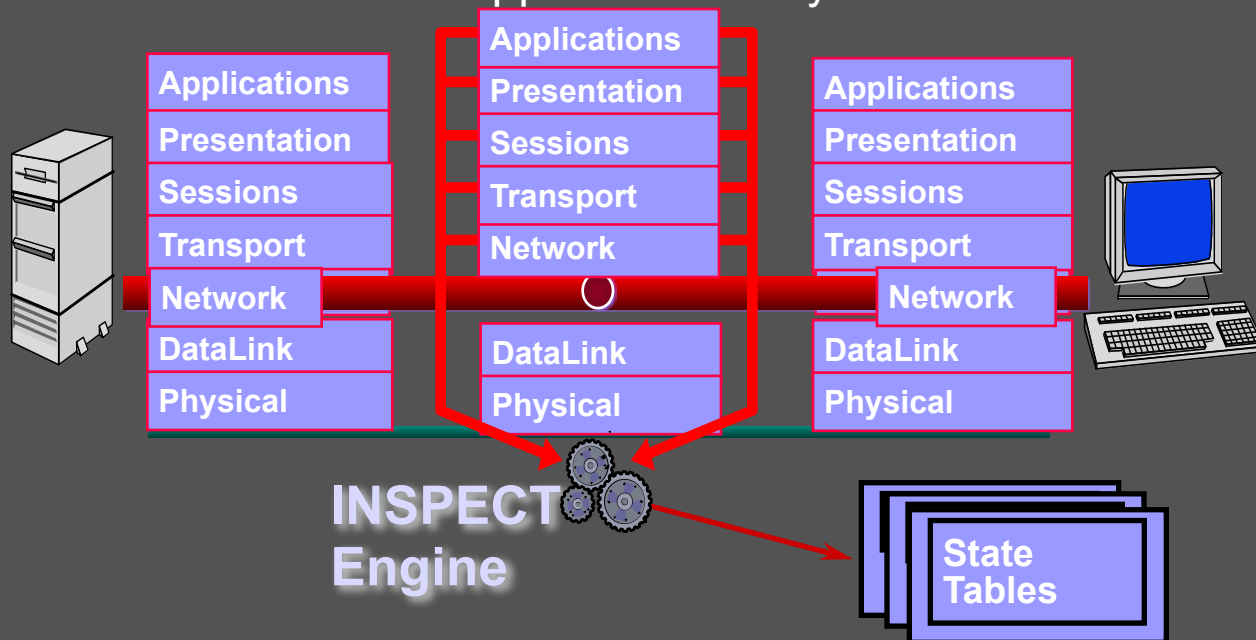
Firewalls – Stateful Packet

- **Advantages**

- Operates at 2nd/3rd layer in the OSI stack -- faster than Application Proxy
- Application independent

- **Disadvantages**

- Less access control than Application Proxy



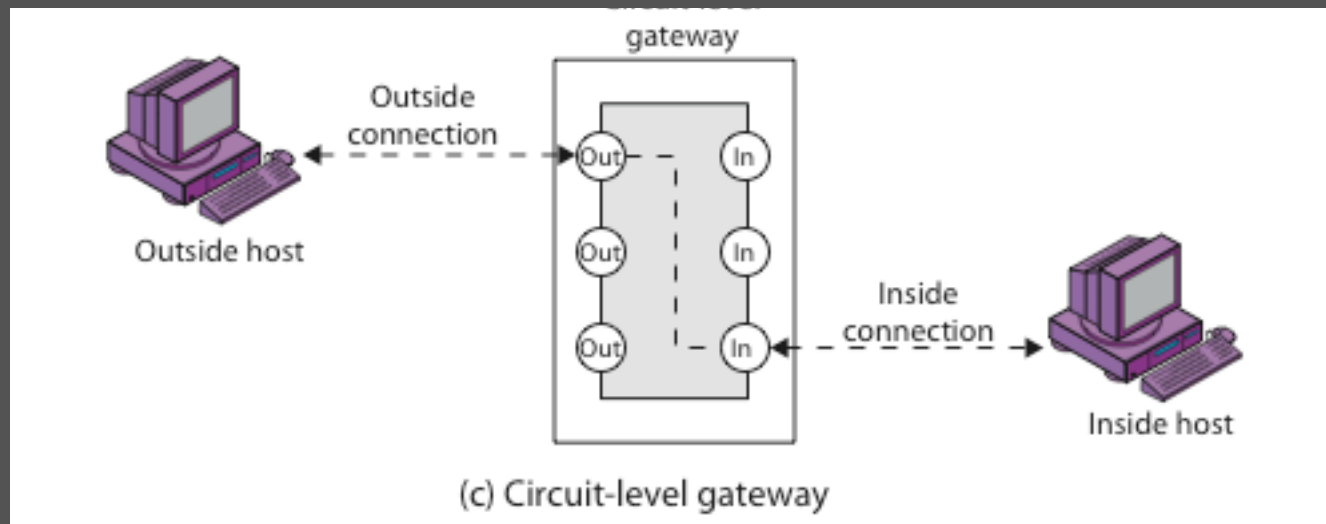
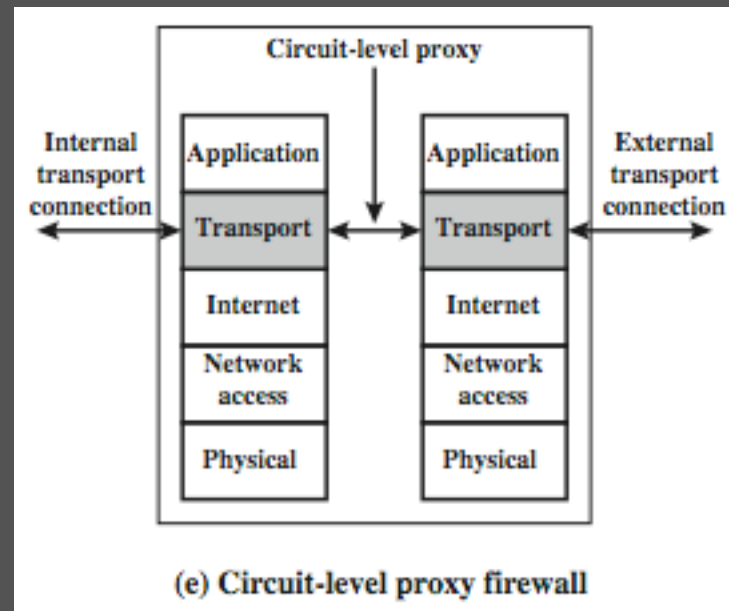
Firewalls - Circuit Level Gateway

- Circuit level firewalls are 3rd generation firewalls.
- Circuit level firewalls are similar in operation to packet-filtering firewalls. The biggest difference is that a circuit-level firewall validates TCP and UDP sessions before opening a connection (or circuit) through the firewall.
- When a session is established, the firewall maintains a table of valid connections and lets data pass through when session information matches any entry in the table.
- The table entry is removed and the circuit is closed when the session is terminated.

Firewalls - Circuit Level Gateway

- relays two TCP connections
- imposes security by limiting which such connections are allowed
- once created usually relays traffic without examining contents
- typically used for trusted internal users by allowing general outbound connections
- SOCKS is commonly used

Firewalls - Circuit Level Gateway



Firewalls - Circuit Level Gateway

- When a connection is set up, the circuit level firewall stores the following:
 1. A unique session identifier for the connection.
 2. The state of the connection (handshake, established, closing).
 3. The sequencing information.
 4. The source IP address.
 5. The destination IP address.
 6. The physical network interface through which the data arrives.
 7. The physical network interface through which the data goes out.

Firewalls - Circuit Level Gateway

- Advantages:
 1. They are faster than application layer firewalls.
 2. They are more secured than packet filter firewalls.
 3. They protect against spoofing of packets.
 4. They shield internal IP addresses from external networks by NAT (network address translation).
- Disadvantages:
 1. They can not restrict access to protocol subsets other than TCP.
 2. They can not perform security checks on higher level protocols.

Firewalls - Application Level Gateway (or Proxy)

- have application specific gateway / proxy
- has full access to protocol
 - user requests service from proxy
 - proxy validates request as legal
 - then actions request and returns result to user
 - can log / audit traffic at application level

3- Application Level Firewalls

- An application level firewall is third generation firewall technology that evaluates network packets for valid data at the application layer before allowing a connection.
- It maintains a complete list of connection states and sequencing information.
- Application level firewalls validates the security items that appear only in the application layer protocols, such as user passwords and service requests.
- It uses special purpose programs to act as a proxy to manage data transfer through the firewall for specific services such as *ftp* and *http*.

3- Application Level Firewalls

Advantages:

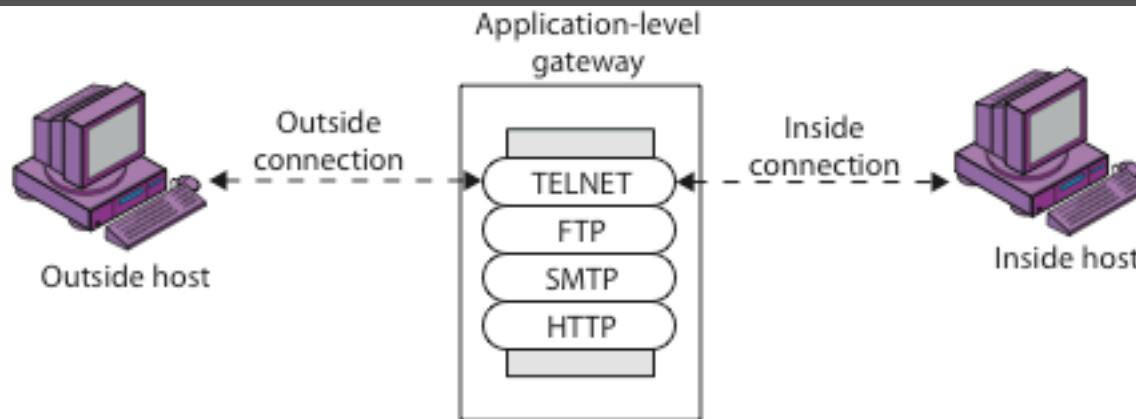
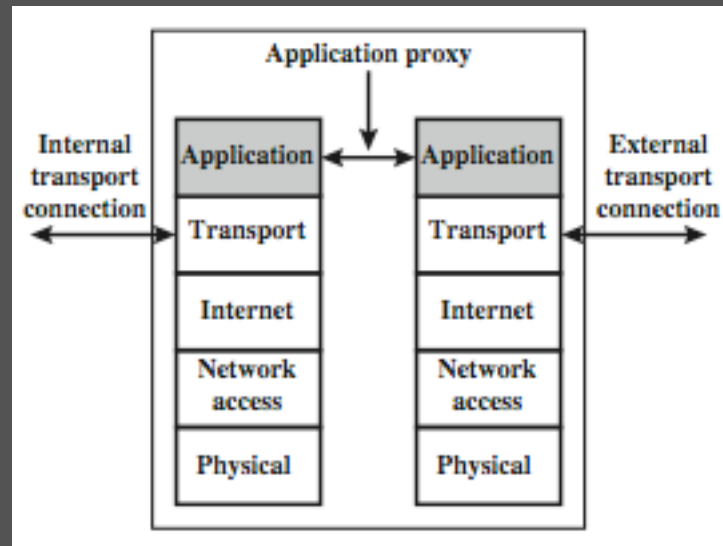
- They understand high level protocols, like *http* and *ftp*.
- They can be used to deny access to certain network services, while allowing others.
- They do not allow direct communication between external servers and internal systems, thus they shield internal IP addresses from external networks.
- They provide features like *HTTP* caching, URL filtering, and user authentication.

3- Application Level Firewalls

Disadvantages:

- They require replacing the native network stack on the firewall server.
- They are slow.
- Proxy services require modifications to client procedures.
- They rely on operating system support and thus are vulnerable to bugs in the system.

Firewalls - Application Level Gateway (or Proxy)



(b) Application-level gateway

Bastion Host

- highly secure host system, special entrance for admin
- runs circuit / application level gateways
- or provides externally accessible services
- potentially exposed to "hostile" elements
- hence is secured to withstand this
 - hardened O/S, essential services, extra auth
 - proxies small, secure, independent, non-privileged
- may support 2 or more net connections
- may be trusted to enforce policy of trusted separation between these net connections

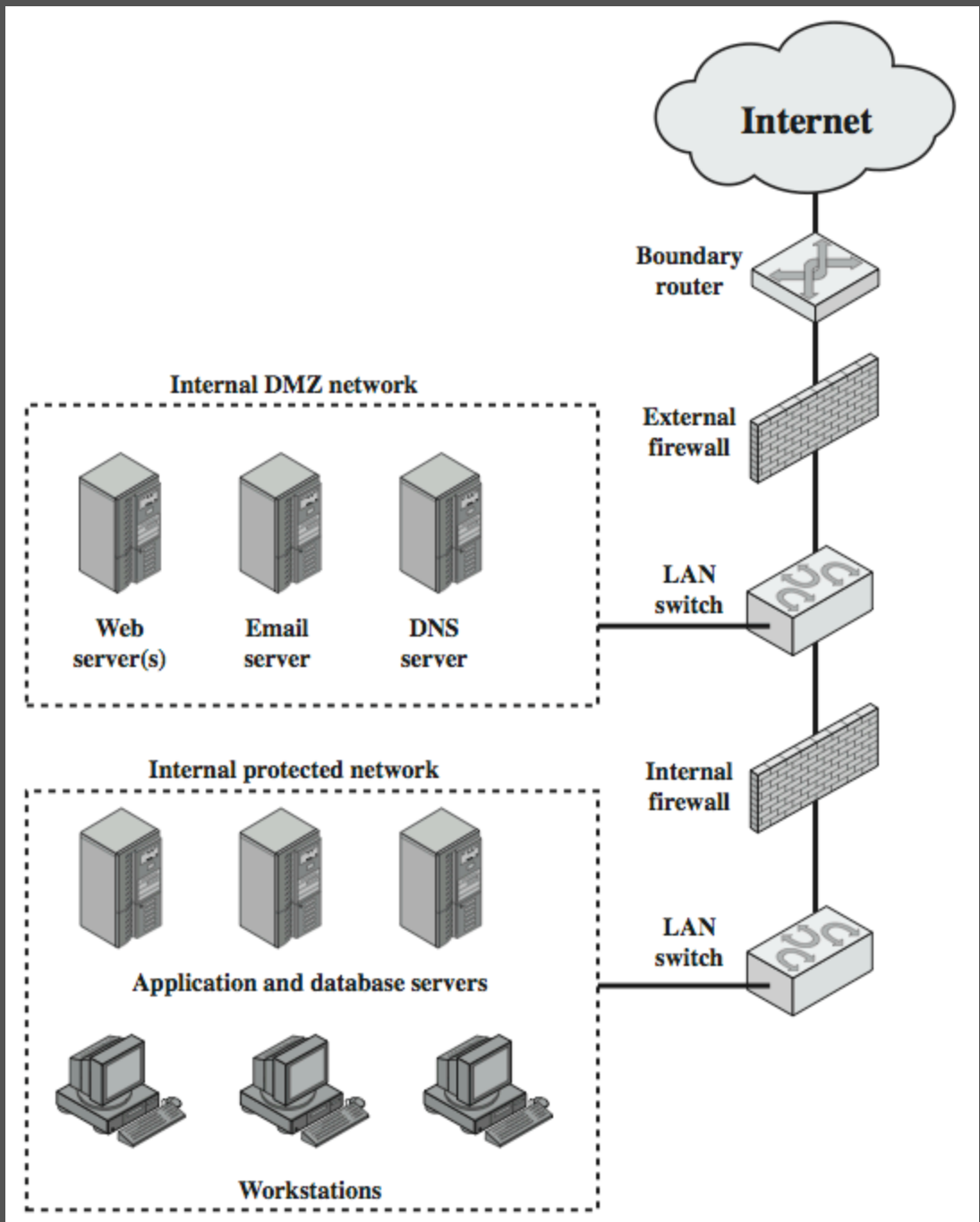
Host-Based Firewalls

- s/w module used to secure individual host
 - available in many operating systems
 - or can be provided as an add-on package
- often used on servers
- advantages:
 - can tailor filtering rules to host environment
 - protection is provided independent of topology
 - provides an additional layer of protection

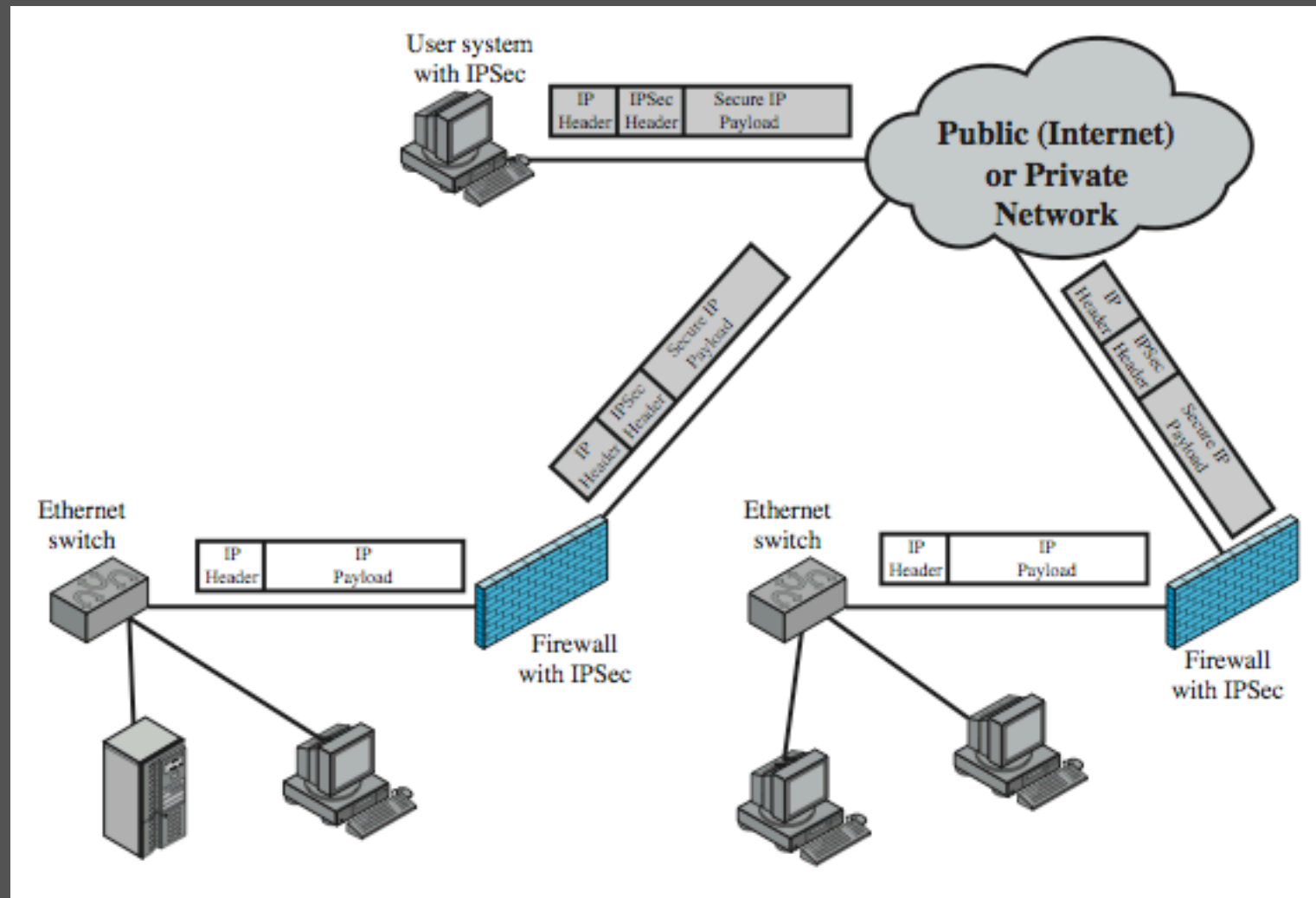
Personal Firewalls

- controls traffic between PC/workstation and Internet or enterprise network
- a software module on personal computer
- or in home/office DSL/cable/ISP router
- typically much less complex than other firewall types
- primary role to deny unauthorized remote access to the computer
- and monitor outgoing activity for malware

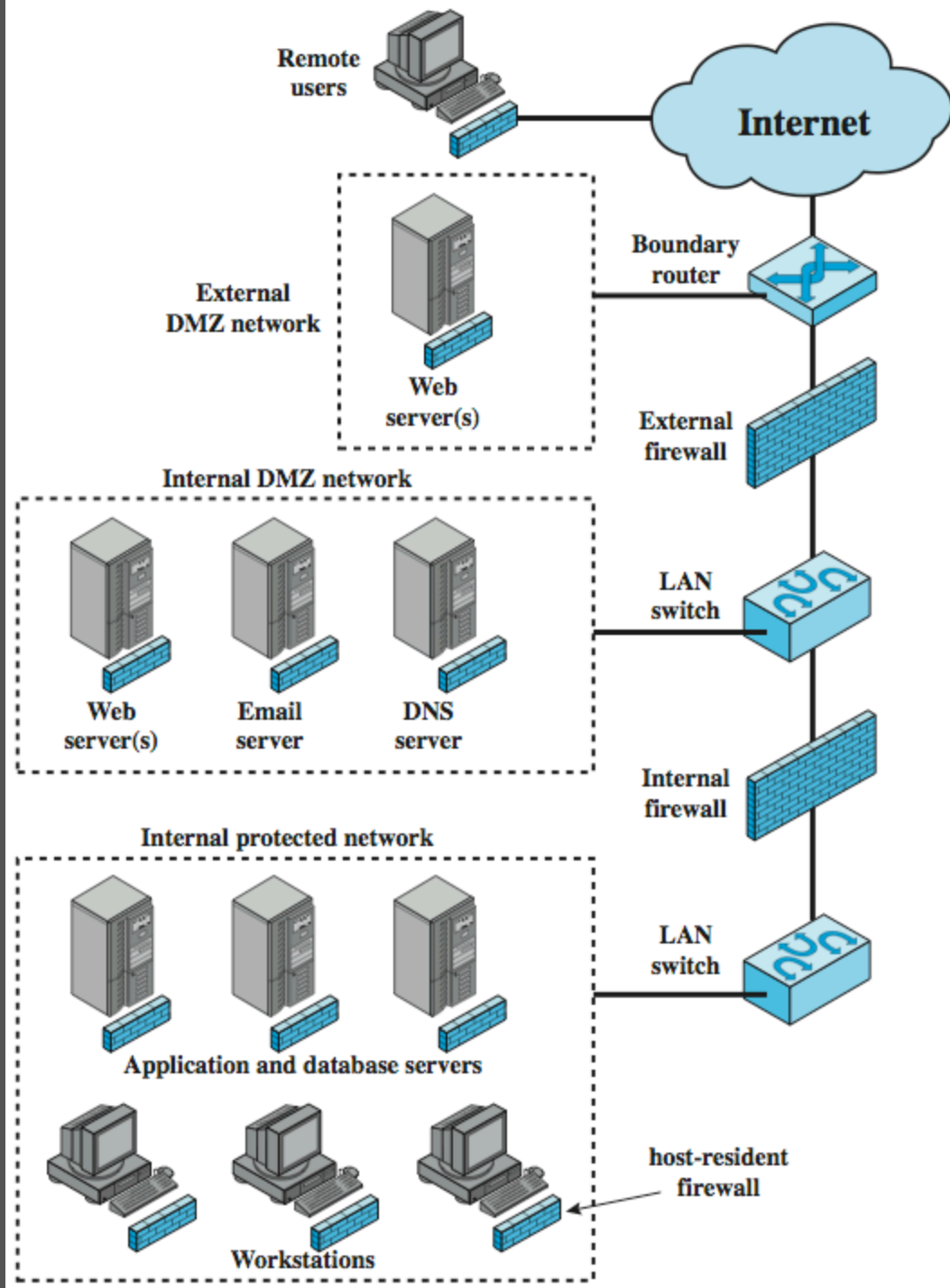
DMZ Networks



Virtual Private Networks



Distributed Firewalls



Summary

- We have learned:
 - firewalls
 - types of firewalls
 - packet-filter, stateful inspection, application proxy, circuit-level
 - basing
 - bastion, host, personal
 - location and configurations
 - DMZ, VPN, distributed, topologies

Intrusion Detection Systems

Intrusion Detection Systems (IDS)

- *Monitors* network/system activity
- Can use different sources of information
- Tries to *identify malicious* activities
- Scans for *patterns* that might indicate a threat
- Or scans for *abnormalities*
- Compiles *security relevant* events

Taxonomy

- Host-based Intrusion Detection Systems (HIDS)
analyse host-level information
 - Network-based Intrusion Detection Systems (NIDS)
capture & analyse network traffic
 - Logging-based Intrusion Detection Systems (LIDS)
analyse collected logging
 - *Misuse vs. anomaly* detection
 - *Passive vs reactive* systems
- ... and yes, these aren't non-overlapping categories ...

What to detect

Misuse detection

- Searches for known *attack signatures*
- ⇒ Susceptible to unknown attacks

Anomaly detection

- Classical machine learning domain
 - Learn normal patterns of operation
 - Detect deviations from normal operation
- ⇒ Susceptible to false positives

How to React

Passive systems filter information, extract relevant events

⇒ Source of distilled information

Reactive systems

- *Intrusion Prevention Systems (IPS)*
- Designed to take action, e.g.,
- change firewall rules,
- block users,
- change network connectivity

IDS Approaches

- Preemptive blocking
- Intrusion deflection
- Intrusion deterrence

Preemptive Blocking

- Called *banishment vigilance*
- Seeks to prevent intrusions before they occur
- Notes any sign of impending threats and blocks the user or IP
- Risk of blocking legitimate users, i.e., risk of a denial of service

Intrusion Deflection

- **Honeypot** – an attractive system with fake (but seemingly realistic) data, services, etc.
- Lure the attacker into the system and monitor attacker's activity
- Detect ongoing attacks and learn about new attacks
- Collect information for forensics

Intrusion Deterrence

- An attempt to make the system a less palatable target
- E.g., having a visible intrusion detection system
- It indicates that activity might be noticed
- And also that actions might then be taken
- Whom this impresses is another story

Example Systems

- Manifold IDS/IPS systems & vendors
 - Determine which is best on system context
 - ... and requirements
 - Examples: (partially not exactly IDSs)
 - [suricata](#) 
 - [Snort](#) 
 - The [Zeek Network Security Monitor](#) 
- all free and open-source

Summary—Intrusion Detection

- Isolate security relevant events
- Fusing information from different sources
- Logging from services & firewalls
- Network capture
- Use automatic systems to collect & analyse the flood
- Monitor system state (with other statistics)
- And—where possible—act on the analytics

What if ...

- You have your policies,
- your threat aware development process,
- your monitoring system ...
- a system for reporting & tracking issues/incidents internal & external
- But something went wrong: are you prepared?

Immediate Incident Response

- Verification: information correct
- Interpretation: what actually happened
- Scope of incident: actual & possible consequences
- classification & prioritisation: how do you have to act?
E.g., spam vs. scanning vs. compromised system

Next Steps

- Forensics: research what went wrong
how and when do you secure the evidence?
- Restore operations: how to rebuild the systems
 - priorities
 - backups
 - plan for how to get what back online
- These two aims can counteract each other!
- Communication
internal/business partners & investors/customers